

CharityHub

Nonprofit Donation & Campaign Management System



Technical Documentation

Course	CET232 – Web and Security
Department	Computer Engineering Technology
Program	Network and Cyber Security Technology
Team Members	Mohamed Helmy, Mostafa Salah, Amir Khaled, Mahmoud Mohamed
Date	May 13, 2026

Table of Contents

Table of Contents.....	2
1. Database Schema	4
1.1 Core Tables Overview	4
1.2 Entity Relationship Overview	4
1.3 Financial Log – Immutable Audit Trail.....	5
2. Payment Flow – Stripe Integration	6
2.1 One-Time Donation Flow	6
2.2 Recurring Donation Flow	6
2.3 Subscription Cancellation	7
2.4 Refund Processing	7
3. API Documentation	8
3.1 Authentication.....	8
3.2 Donor Endpoints.....	8
3.3 Admin / Employee Endpoints.....	8
3.4 Request & Response Format	9
4. Donor-Facing User Guide	10
4.1 Making a One-Time Donation	10
4.2 Setting Up a Recurring Donation	10
4.3 Managing Subscriptions & Cancellations.....	10
4.4 Donor Dashboard	10
4.5 Privacy & Anonymous Donations.....	11
5. Admin Operations Manual.....	12
5.1 Financial Management	12
5.1.1 Ledger & Audit Trail	12
5.1.2 Processing Refunds	12
5.2 GDPR & Data Subject Requests	12
5.3 Campaign Management	13
5.4 Volunteer Coordination	13
5.4.1 Managing Applications	13
5.4.2 Approving Volunteer Hours	13
5.4.3 Creating Volunteer Events	13
6. Compliance & Data Security	14
6.1 GDPR Compliance Framework.....	14
6.2 Data Subject Rights – System Support.....	14
6.3 Payment Security (PCI-DSS).....	14
6.4 Fraud Detection Controls.....	15

6.5 Security Infrastructure	15
-----------------------------------	----

1. Database Schema

CharityHub utilizes a relational database structure centered on three core domains: Fundraising, Volunteering, and Operations. Each domain is represented by a set of normalized tables with clearly defined foreign key relationships to ensure referential integrity and auditability.

1.1 Core Tables Overview

Table	Description	Key Fields
Users	Authentication and role-based access control (RBAC)	id, email, role (admin employee user), password_hash
Donors	Donor profiles with GDPR consent tracking	id, user_id, gdpr_consent, gdpr_consent_at
Campaigns	Fundraising targets and lifecycle management	id, title, goal_amount, status (active paused completed ended)
Donations	Records of one-time and recurring payments	id, donor_id, campaign_id, amount, type, gateway_transaction_id
Subscriptions	Recurring billing management via Stripe	id, donor_id, stripe_subscription_id, frequency, status
Financial Logs	Immutable append-only audit trail with tamper detection	id, donation_id, sha256_hmac_hash, action, created_at
Volunteers	Volunteer profiles: skills, availability, hours	id, user_id, skills, availability, approved_hours
Volunteer Events	Public volunteering opportunities	id, title, date, location, max_attendees

1.2 Entity Relationship Overview

The diagram below illustrates the primary relationships between core entities:

USER	--o	DONOR	"is"
USER	--o	VOLUNTEER	"is"
DONOR	--o{	DONATION	"makes"
CAMPAIGN	--o{	DONATION	"receives"
DONOR	--o{	SUBSCRIPTION	"starts"

```
SUBSCRIPTION ||--o{ DONATION "generates"  
DONATION ||--o| FINANCIAL_LOG "audited_by"  
VOLUNTEER ||--o{ VOLUNTEER_APPLICATION "submits"  
VOLUNTEER_EVENT ||--o{ VOLUNTEER_APPLICATION "receives"
```

1.3 Financial Log – Immutable Audit Trail

The Financial Log table is a critical security component. It is append-only – no record can be updated or deleted. Every entry stores a SHA-256 HMAC hash of the transaction data. If any record is altered post-insertion, the hash comparison will fail and the admin dashboard will display a "Tampered" warning.

⚠ Financial Logs are IMMUTABLE – append-only by design.
Each entry is protected with a SHA-256 HMAC hash.
Retention Policy: Financial records are retained for 7 years; audit logs for 3 years.

2. Payment Flow – Stripe Integration

CharityHub integrates with Stripe for all payment processing. No card data is ever stored on the local application servers – tokenization is handled entirely by Stripe, ensuring PCI-DSS compliance.

2.1 One-Time Donation Flow

Step	Actor	Description
1	Client (Browser)	Donor selects campaign and enters amount. A unique idempotency_key is generated client-side to prevent duplicate charges.
2	Backend (Laravel)	Backend creates a Stripe Checkout Session with the amount, campaign metadata, and idempotency key.
3	Stripe	Donor is redirected to Stripe's PCI-compliant hosted checkout page to complete payment securely.
4	Stripe → Backend	On success, Stripe fires the charge.succeeded webhook to the backend endpoint.
5	Backend	System updates donation record to "completed", generates an immutable financial_log entry, and triggers automatic tax certificate generation as a PDF.

2.2 Recurring Donation Flow

Step	Actor	Description
1	Client	Donor opts in to "Make it recurring" during checkout and selects frequency (Monthly or Yearly).
2	Backend + Stripe	A Stripe Subscription is created and linked to the donor profile in the Subscriptions table.
3	Stripe	Stripe automatically handles billing on each renewal cycle.
4	Stripe → Backend	On each successful renewal, Stripe fires invoice.payment_succeeded webhook.
5	Backend	A new Donation record and a new immutable Financial Log entry are created for each successful renewal.

2.3 Subscription Cancellation

Donors may cancel any active recurring subscription at any time through their dashboard. Cancellation is immediate and calls the Stripe API to cancel the subscription, preventing any future charges. An immutable log entry is created to record the cancellation event.

2.4 Refund Processing

Administrators can process refunds directly through the Admin Dashboard. The refund action triggers a Stripe API reversal and records an immutable Financial Log entry with the refund details. Refunds cannot be deleted from the audit trail.

- ✓ PCI-DSS Compliant: No card data stored on application servers.
- ✓ Idempotency Keys prevent duplicate charges.
- ✓ All payment events (charge, renewal, refund, cancellation) generate immutable audit log entries.

3. API Documentation

The CharityHub API is built on Laravel and provides RESTful endpoints for donation processing, donor management, volunteer coordination, and administrative operations. Authentication is required for all non-public endpoints.

3.1 Authentication

Method	Details
Laravel Session	Used for browser-based interactions via the web application.
Bearer Token	Used for API-based integrations. Pass the token in the Authorization header: Bearer {token}

3.2 Donor Endpoints

Method + Endpoint	Auth	Description
POST /donate/checkout	Public	Initialize a Stripe Checkout Session. Required body: amount, campaign_id, gdpr_consent. Optional: anonymous (boolean), recurring (boolean), frequency.
GET /donor/dashboard	Donor	Retrieve donor statistics, active subscriptions, and available tax certificates.
POST /donor/subscriptions/{id}/cancel	Donor (Owner)	Immediately cancel a specific recurring subscription. Calls Stripe API and creates an immutable log entry.
GET /verify/{uuid}	Public	Verify the authenticity of a donation tax certificate by its unique UUID. Returns donor and campaign metadata.

3.3 Admin / Employee Endpoints

Method + Endpoint	Auth	Description
GET /admin/ledger	Admin / Employee	Access the full immutable financial audit trail. Returns paginated log entries with hash validation status.
POST /admin/refund/{donation_id}	Admin	Process a refund for a completed donation. Triggers Stripe API reversal and creates an audit log entry.

Department of Computer Engineering Technology Network and Cyber Security Technology Program

CET232 – Web and Security

Charity Hub Nonprofit Donation & Campaign Management

Project By: Mohamed Helmy – Mostafa Salah - Amir Khaled –
Mahmoud Mohamed



GET /admin/donors	Admin / Employee	List all donors with optional filters (GDPR status, date range, campaign).
GET /admin/volunteers	Admin / Employee	List all volunteer profiles with application and hours status.
PUT /admin/volunteer-hours/{id}/approve	Admin / Employee	Approve or reject logged volunteer hours to update public impact metrics.
GET /admin/campaigns	Admin / Employee	List and manage all fundraising campaigns with status and progress.

3.4 Request & Response Format

All requests and responses use JSON. Always include the Content-Type header:

```
Content-Type: application/json
```

```
Accept: application/json
```

Example – Initiating a one-time donation checkout:

```
POST /donate/checkout
```

```
{
  "amount": 5000,
  "campaign_id": 12,
  "gdpr_consent": true,
  "anonymous": false,
  "recurring": false
}
```

4. Donor-Facing User Guide

This section provides a step-by-step guide for donors interacting with the CharityHub platform. The interface is designed to be intuitive, transparent, and privacy-respecting.

4.1 Making a One-Time Donation

1. Browse the Campaigns page and select a campaign you wish to support.
2. Enter your desired donation amount in the amount field.
3. Optionally toggle "Anonymous" to hide your name from public donor lists.
4. Click "Donate Now" to proceed to Stripe's secure hosted checkout page.
5. Complete your payment details on Stripe's PCI-compliant page.
6. Upon success, you will be redirected to a confirmation page and receive a PDF tax certificate by email.

4.2 Setting Up a Recurring Donation

7. Follow steps 1–3 from the one-time donation process above.
8. Before proceeding to checkout, toggle the "Make it Monthly" option.
9. Complete the Stripe checkout. Your subscription is now active.
10. A new tax certificate is generated automatically after each successful renewal.

4.3 Managing Subscriptions & Cancellations

All active subscriptions are visible in your Donor Dashboard under the "My Subscriptions" tab. You may cancel any subscription at any time by clicking "Cancel Subscription." Cancellation takes effect immediately – no further charges will be made.

4.4 Donor Dashboard

Feature	Description
Donation History	View a full history of all one-time and recurring donations with dates and amounts.
Active Subscriptions	See all currently active recurring donations with next billing date and frequency.

Tax Certificates	Download PDF tax certificates for any completed donation. Certificates are auto-generated after payment.
Certificate Verification	Share a certificate verification link (unique UUID) with authorities to authenticate its validity.
Data Portability	Download all your personal data in JSON format from Account Settings (GDPR Article 20 right).
Account Settings	Update profile information, change password, and manage marketing consent.

4.5 Privacy & Anonymous Donations

Donors who prefer privacy can use the "Anonymous" toggle during checkout. When anonymous, the donor's name will not appear in any public donor lists or campaign leaderboards. Internal records are still maintained for tax and legal compliance purposes.

-  Your payment data is never stored on CharityHub servers.
-  Anonymous donations are not publicly attributed to your name.
-  You may request full erasure of your data at any time (subject to legal retention obligations).

5. Admin Operations Manual

This section is intended for platform administrators and employees. It covers financial management, GDPR data operations, volunteer coordination, and campaign management.

5.1 Financial Management

5.1.1 Ledger & Audit Trail

The Admin Ledger (/admin/ledger) provides a real-time view of all financial transactions. Each entry displays the transaction details alongside its SHA-256 HMAC hash. If any entry has been tampered with externally, a red "Tampered" warning badge will appear next to that record. The ledger is read-only – entries cannot be edited or deleted.

⚠ A "Tampered" warning indicates the stored hash does not match the computed hash for that record.

This may indicate unauthorized database modification. Escalate immediately to the security team.

5.1.2 Processing Refunds

- Navigate to Donations and locate the relevant donation record.
- Click "Issue Refund" and confirm the refund amount.
- The system calls the Stripe API to reverse the charge.
- An immutable refund entry is automatically added to the Financial Log.
- The donor is notified by email of the successful refund.

5.2 GDPR & Data Subject Requests

Request Type	Admin Action	Notes
Access (DSAR)	Navigate to Donor Profile > Export Data	Exports all personal data as JSON. Must be fulfilled within 30 days.
Rectification	Navigate to Donor Profile > Edit	Correct inaccurate personal data directly from the dashboard.
Erasure (Right to be Forgotten)	Navigate to Donor Profile > Anonymize	Anonymizes personal data. Financial transaction records are retained per legal obligation (7 years).
Consent Withdrawal	Navigate to Donor Profile > Manage Consent	Removes marketing consent. Does not affect contractual processing of donation transactions.

5.3 Campaign Management

Status	Description	Admin Action Available
Active	Campaign is live and accepting donations.	Pause, Edit, End
Paused	Campaign is temporarily halted; new donations blocked.	Resume, End
Completed	Campaign goal has been reached.	View Only, Generate Report
Ended	Campaign has been manually closed by admin.	View Only, Archive

5.4 Volunteer Coordination

5.4.1 Managing Applications

- Navigate to Volunteer Management > Applications.
- Review each application and click "Approve" or "Reject."
- Approved volunteers are notified by email and gain access to the volunteering portal.

5.4.2 Approving Volunteer Hours

- Navigate to Volunteer Management > Hours Log.
- Review hours submitted by volunteers after events.
- Click "Approve" to validate hours – this updates the platform's public impact metrics.

5.4.3 Creating Volunteer Events

- Navigate to Volunteer Events > Create New Event.
- Fill in title, date, location, description, and maximum attendees.
- Publish the event to make it visible on the public volunteering page.
- Volunteers may then submit applications through the public event listing.

6. Compliance & Data Security

6.1 GDPR Compliance Framework

Lawful Basis	Processing Activity	Retention Period
Consent	Marketing communications, newsletter opt-in, public donor listing	Until consent is withdrawn
Contract	Processing donations, managing subscriptions, issuing tax certificates	Duration of relationship + 7 years
Legal Obligation	Tax reporting, financial audit records, fraud investigation	7 years (financial) / 3 years (audit logs)

6.2 Data Subject Rights – System Support

Right (GDPR Article)	System Feature
Art. 15 – Right of Access	DSAR export tool: full JSON export of all personal data from the Admin panel.
Art. 16 – Right to Rectification	Admin can edit donor profile data directly from the dashboard.
Art. 17 – Right to Erasure	Anonymization tool: replaces personal identifiers with anonymized tokens. Financial records are retained per legal obligation.
Art. 20 – Data Portability	Donors can self-download all their personal data in JSON format from Account Settings.
Art. 21 – Right to Object	Consent management panel allows donors to withdraw marketing consent independently of donation processing.

6.3 Payment Security (PCI-DSS)

Control	Implementation
No Local Card Storage	All card data is tokenized by Stripe. CharityHub servers never receive or store raw card numbers.
Encrypted Transport	All traffic is enforced over HTTPS / TLS 1.2+. HTTP requests are automatically redirected.

Tokenization	Stripe handles all payment tokenization. Only Stripe payment method IDs are stored locally.
Webhook Signature Verification	All Stripe webhook events are verified using Stripe's HMAC signature before processing.

6.4 Fraud Detection Controls

Detection Method	Description
IP Velocity Checks	Detects unusually high transaction frequency from a single IP address within a short time window.
Email Verification	Donor email addresses are verified before donation processing to prevent fraudulent accounts.
Transaction Amount Limits	Configurable maximum transaction limits per session to flag abnormally large donations for review.
Idempotency Keys	Prevents duplicate charges from network retries or browser back-button resubmissions.

6.5 Security Infrastructure

- All passwords are hashed using bcrypt with a minimum cost factor of 12.
- Role-Based Access Control (RBAC) restricts access to admin and employee features.
- Session tokens are regenerated on login to prevent session fixation attacks.
- CSRF protection is enabled on all state-changing endpoints via Laravel's built-in middleware.
- SQL injection is mitigated by using Laravel's Eloquent ORM with parameterized queries exclusively.

End of Document